User Authentication, Access Control, and Operating Systems

Intro to User Authentication

Two Steps of Authentication
- Identification — user ID, unique but not secret
- Verification — password, pin ...

Means of Authentication
- knows — password, pin, qn answers
- possesses — token
- is — static biometrics (fingerprint, retina)
- does — dynamic biometrics (voice pattern, handwriting)

Password Based Authentication
- Identity
- Password

Vulnerability of Passwords
- Offline Dictionary Attack — Countermeasure : control access to DB
- Specific Account Attack — lock account after failed attempts
- Popular Password Attack — block computers that make multiple attempts
- Password Guessing Against a Single User — train users in password selection
- Computer Hijacking — auto-logout
- Exploiting User Mistakes — user training, 2FA
- Exploiting Multiple Password Use — control selection of passwords across devices
- Electronic Monitoring — encrypt communications that send passwords

Storing Passwords

Insider Attack

Outsider Attack

Encrypting Passwords
- drawback : Secret key must be stored (on file/memory)
- if attacker can read database, then likely they can read key

Hash the Passwords

Cracking Passwords

Brute Force Attack on Hashed Passwords
- Attack duration depends on size of possible password set
- on n-bit hash value : 2^n attempts Ex: MD5 128 bit needs 2^{128} attempts
- Easier to find password rather than hash of password 94 total characters avail on keyboard

Rainbow Tables & Salting

Rainbow Tables
- Does not include easy passwords like 00000000 which reduces space req.
- for rainbow tables — up to 1.7TB
- Trade offs
  - reduce search time, increase storage space
- Countermeasures
  - longer passwords, slower hash algos, salt the password before hash

Salting Passwords
- put random s-bit value (salt), add to end of password
- now rainbow tables no longer feasible
  - space required increased by factor of 2^s

UA Token Based Authentication

Memory Cards
- Store but do not process data
- ex : hotel card

Smart Cards
- Contains microprocessor
- looks like credit card

Smart Token
- eg : DBS token

Electronic ID Cards (eID)

Biometric Authentication
- face, iris, fingerprint, voice ...

Intro to Access Control (AC)

What is Access control?
- the door inside the system that controls what you can access
- Authentication — verify that user credentials are valid
- Authorization — grant permission to a system entity to access resource
- Audit — independent review of system records to test system control
  - ensure compliance, detect breaches
- Subject — classified further into owner, group, world
- Object — a resource to which access is controlled
- Access right — the way a subject may access an object

General requirements of Access Control
- Reliable input
- Fine and coarse specifications
- Least Privilege
- Seperation of duty
- Open & Closed policies ☆most used
- Policy combinations & conflict resolution
- Administrative policies
- Dual control

Types of Access Controls (Part 1)

Access Control Policies
- Discretionary Access Control (DAC)
  - controls access based on the identity of requester and on access rules (authorizations) stating what requesters can or cannot do Ex: Access Matrix, Access Control Lists, Capability Lists, Authorization Table
- Mandatory Access Control (MAC)
  - Controls access based on comparing security labels with security clearances
- Role-based Access Control (RBAC)
  - Controls access based on roles the users have on system and on rules stating what access is allowed for each role
  - roles can be static & dynamic
  - Constraints
    - higher role includes all access rights of lower role
    - mutually exclusive : user can only be assigned one role
    - cardinality : max # with respect to roles
      - max # of users assigned to role
      - max # of roles a user can be assigned to
    - prerequisite : condition upon which user can be assigned role
      - user can only be assigned senior if already assigned junior

Types of Access Controls (Part 2)

RBAC
- admin assign access permission to role
- limitations :
  - Role Explosion
  - Toxic Combinations
  - Management Nightmares
  - Lack of Context

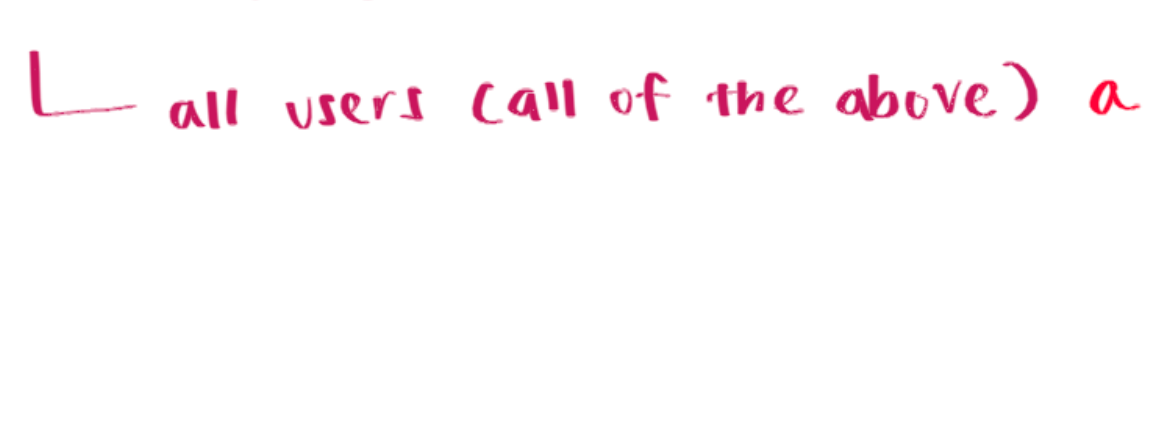
Attribute Based Access Control (ABAC) ☆evolved version of RBAC
- uses attributes of subjects, objects & environment (instead of roles)
- more suitable in adopting dynamic access
  - based on :
    - action →
    - user →
    - subject →
    - object →
    - context →
    - policy →

Authorization Decision → Yes/No

MAC
- based on multi-level security (MLS)
  - top secret > secret > confidential > restricted > unclassified
- subject has security clearance
- object has security classification
- two required properties for confidentiality
  - no read up
  - no write down
- Drawback : all goes through administrator

AC UNIX/LINUX Access Control

UNIX File Access Control
- administered using inodes (index nodes)
- directories are structured in a hierarchical tree



inode
- mode : 16 bits
- owner id
- group id
- size
- time stamps
- ...
- permissions
  - read, write, execute
- special permissions
  - setuid bit
  - setgid bit
  - sticky bit

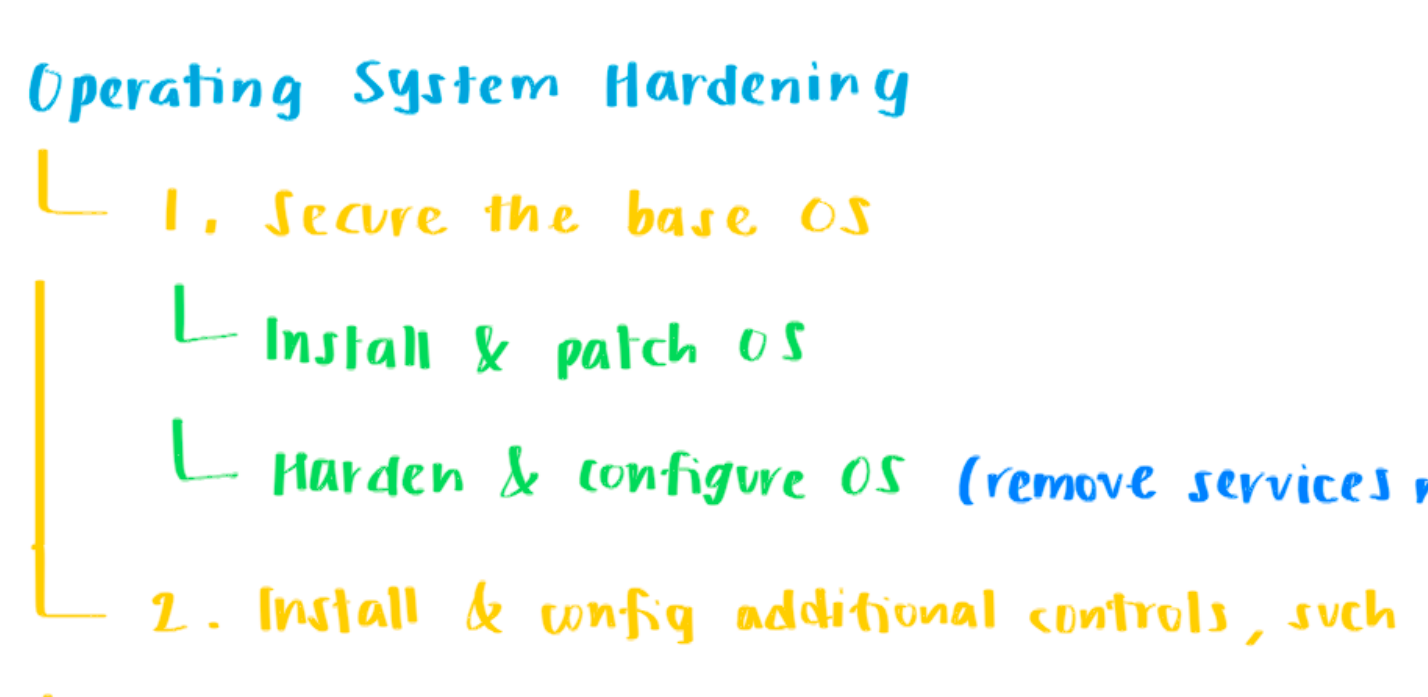
categories

user that owns the file	u
users in the file's group	g
other users	o
all users (all of the above)	a

Operating System Security

Operating System Strategy
- white list approved apps
- patch third party apps & OS vulnerabilities
- restrict admin privileges
- create a defense in depth system

System Security Planning



The first step in deploying a new system is planning

Plan needs to identify appropriate personnel and training to install and manage the system

Planning should include a wide security assessment of the organization

Planning process needs to determine security requirements for the system, applications, data, and users

Aim is to maximize security while minimizing costs

Operating System Hardening
- 1. Secure the base OS
  - Install & patch OS
  - Harden & configure OS (remove services not needed, config user & group & permissions)
- 2. Install & config additional controls, such as anti-virus, host-based firewalls and IDS
- 3. Test security of OS to ensure steps taken adequately address security needs

Operating System Security Part 2

Recap from part 1 above
- remove unnecessary services, applications, protocols
- configure users, groups, and authentication
- configure resource control
- install additional security controls
- test the system security

Application Configuration
- security policy can control app execution
  - white-listing & black-listing
- of particular concern with remotely accessed services such as web & file transfer services

Encryption Technology

Security Maintainence
- process is continuous
  - monitor & analyze log data
  - perform regular backups
  - recovering from compromises
  - regular security testing
  - patch & update all critical software

Logging
- an automatic analysis of logs is preferred

Data Backup & Archive
- depends on needs of company/organization
- archive means retaining data backups